

CYBERSECURITY

CIA Triad Analysis

The CIA Triad is a fundamental model in information security consisting of **Confidentiality, Integrity, and Availability**. These three principles help organizations protect information and ensure that systems operate securely and reliably.

1. Confidentiality

Confidentiality means protecting information from unauthorized access or disclosure. Only authorized individuals should be able to access sensitive information.

Examples of confidentiality controls:

1. Passwords
2. Multi-factor authentication
3. Encryption
4. Access control
5. User permissions

Example: in a hospital the doctors must ensure that the patients record is handled by the authorized people like the doctors, staff and patients.

2. Integrity

Integrity means ensuring that information remains accurate, complete, and trustworthy. Data should not be changed or deleted by unauthorized users.

Examples of integrity controls:

1. Hashing
2. Digital signatures
3. File permissions
4. Version control
5. Data validation

Example: in online banking, a transaction amount should not be modified by an unauthorized person while the transaction is being processed.

3. Availability

Availability means ensuring that authorized users can access systems and information when they need them.

Examples of availability controls:

1. Regular backups
2. Redundant servers
3. Disaster recovery
4. System monitoring

5. Protection against DoS/DDoS attacks

Example: An online banking website should remain accessible to customers even during periods of high traffic or attempted cyberattacks.

Therefore, the importance of the CIA is that these three principles must work together to provide a balanced approach to the information security. A security incident can affect one or more parts of the CIA Triad. Therefore, organizations need security measures that protect confidentiality, maintain data integrity, and ensure system availability.

REAL-WORLD EXAMPLES

Example 1 — Data Breach

Incident: An organization experiences a data breach and attackers obtain customer's personal information. Here the CIA principle affected is confidentiality, the sensitive information was accessed by the unauthorized people. So in order to avoid that we can use algorithms to encrypt the message and access control should be handled carefully.

Example 2 — Ransomware Attack

Incident: Ransomware encrypts an organization's files, preventing employees from accessing important documents and systems. Here the CIA principle affected is availability, because the employees are unable to access their important data and systems. It can also affect integrity because the original files may be modified or encrypted by the attacker. So, in order to avoid this, we can take regular backups of important files, use antivirus and endpoint security, keep software updated, and monitor the network carefully.

Example 3 — Unauthorized Modification of Financial Data

Incident: An attacker gains unauthorized access to a company's database and changes important financial records. Here the CIA principle affected is integrity, because the information has been modified without authorization and can no longer be considered trustworthy. So, in order to avoid this, we can use proper access control, secure the database, maintain audit logs, use hashing to verify data, and enable multi-factor authentication.

Example 4 — DDoS Attack on a Website

Incident: Attackers send a large amount of traffic to an organization's website, causing the website to become unavailable to legitimate users. Here the CIA principle affected is availability, because authorized users are unable to access the website when they need it. So in order to avoid this, we can use DDoS protection, traffic filtering, firewalls, load balancing, and redundant servers to keep the service available.

Example 5 — Employee Accidentally Shares Confidential Information

Incident: An employee accidentally sends a confidential company document to an unauthorized person. Here the CIA principle affected is confidentiality, because sensitive information has been disclosed to someone who should not have access to it. So in order to avoid this, we can use proper access controls, provide security awareness training to employees, use data loss prevention tools, and apply strong email security measures.

